1. LEFT (No ZWSP)

เว็บแอปพลิเคชันในปัจจุบันจำนวนมากเพิ่มแชตบอต (Chatbot)
ให้ผู้ใช้ถามข้อมูลด้วยภาษาธรรมชาติแทนการกรอกแบบฟอร์มค้นหา
เบื้องหลังของแชตบอตเหล่านี้คือตัวกลางผสานโมเดลภาษาขนาดใหญ่ (LLM-integration middleware)
อย่าง LangChain และ LlamaIndex ซึ่งส่งคำถามของผู้ใช้ให้โมเดลภาษาขนาดใหญ่ (Large Language
Model: LLM) เขียนคำสั่ง SQL แล้วนำคำสั่งนั้นไปรันกับฐานข้อมูลจริงโดยอัตโนมัติ
ผู้วิจัยชี้ว่าความสะดวกนี้สร้างช่องโหว่รูปแบบใหม่ที่ตั้งชื่อว่า การแทรกคำสั่งจากพรอมต์สู่ SQL (Prompt-to-
SQL Injection: P2SQL) กล่าวคือผู้โจมตีไม่จำเป็นต้องเขียน SQL เอง เพียงพิมพ์ข้อความที่ชักนำให้ LLM
เขียนคำสั่งอันตรายแทน และเนื่องจาก SQL ทั้งประโยคถูกสร้างขึ้นใหม่ทุกครั้ง เทคนิคป้องกัน SQL
Injection แบบดั้งเดิมอย่างการใช้คิวรีแบบกำหนดพารามิเตอร์ (Parameterized Query)
จึงไม่มีจุดให้ยึดเกาะ

2. BOTH (Justify) with ZWSP

เว็บแอปพลิเคชันในปัจจุบันจำนวนมากเพิ่มแชตบอต (Chatbot) ให้ผู้ใช้ถามข้อมูลด้วยภาษาธรรมชาติแทนการกรอกแบบฟอร์มค้นหา เบื้องหลังของแชตบอตเหล่านี้คือตัวกลางผสานโมเดลภาษาขนาดใหญ่ (LLM-integration middleware) อย่าง LangChain และ LlamaIndex ซึ่งส่งคำถามของผู้ใช้ให้โมเดลภาษาขนาดใหญ่ (Large Language Model: LLM) เขียนคำสั่ง SQL แล้วนำคำสั่งนั้นไปรันกับฐานข้อมูลจริงโดยอัตโนมัติ ผู้วิจัยชี้ว่าความสะดวกนี้สร้างช่องโหว่รูปแบบใหม่ที่ตั้งชื่อว่า การแทรกคำสั่งจากพรอมต์สู่ SQL (Prompt-to-SQL Injection: P2SQL) กล่าวคือผู้โจมตีไม่จำเป็นต้องเขียน SQL เอง เพียงพิมพ์ข้อความที่ชักนำให้ LLM เขียนคำสั่งอันตรายแทน และเนื่องจาก SQL ทั้งประโยคถูกสร้างขึ้นใหม่ทุกครั้ง เทคนิคป้องกัน SQL Injection แบบดั้งเดิมอย่างการใช้คิวรีแบบกำหนดพารามิเตอร์ (Parameterized Query) จึงไม่มีจุดให้ยึดเกาะ

3. BOTH (Justify) with ZWSP + Thai Lang tag

เว็บแอปพลิเคชันในปัจจุบันจำนวนมากเพิ่มแชตบอต (Chatbot) ให้ผู้ใช้ถามข้อมูลด้วยภาษาธรรมชาติแทนการกรอกแบบฟอร์มค้นหา เบื้องหลังของแชตบอตเหล่านี้คือตัวกลางผสานโมเดลภาษาขนาดใหญ่ (LLM-integration middleware) อย่าง LangChain และ LlamaIndex ซึ่งส่งคำถามของผู้ใช้ให้โมเดลภาษาขนาดใหญ่ (Large Language Model: LLM) เขียนคำสั่ง SQL แล้วนำคำสั่งนั้นไปรันกับฐานข้อมูลจริงโดยอัตโนมัติ ผู้วิจัยชี้ว่าความสะดวกนี้สร้างช่องโหว่รูปแบบใหม่ที่ตั้งชื่อว่า การแทรกคำสั่งจากพรอมต์สู่ SQL (Prompt-to-SQL Injection: P2SQL) กล่าวคือผู้โจมตีไม่จำเป็นต้องเขียน SQL เอง เพียงพิมพ์ข้อความที่ชักนำให้ LLM

เขียนคำสั่งอันตรายแทน และเนื่องจาก SQL ทั้งประโยคถูกสร้างขึ้นใหม่ทุกครั้ง เทคนิคป้องกัน SQL Injection แบบดั้งเดิมอย่างการใช้คิวรีแบบกำหนดพารามิเตอร์ (Parameterized Query) จึงไม่มีจุดให้ยึดเกาะ

4. LEFT with ZWSP

เว็บแอปพลิเคชันในปัจจุบันจำนวนมากเพิ่มแชตบอต (Chatbot) ให้ผู้ใช้ถามข้อมูลด้วยภาษาธรรมชาติแทนการกรอกแบบฟอร์มค้นหา เบื้องหลังของแชตบอตเหล่านี้คือตัวกลางผสานโมเดลภาษาขนาดใหญ่ (LLM-integration middleware) อย่าง LangChain และ LlamaIndex ซึ่งส่งคำถามของผู้ใช้ให้โมเดลภาษาขนาดใหญ่ (Large Language Model: LLM) เขียนคำสั่ง SQL แล้วนำคำสั่งนั้นไปรันกับฐานข้อมูลจริงโดยอัตโนมัติ ผู้วิจัยชี้ว่าความสะดวกนี้สร้างช่องโหว่รูปแบบใหม่ที่ตั้งชื่อว่า การแทรกคำสั่งจากพรอมต์สู่ SQL (Prompt-to-SQL Injection: P2SQL) กล่าวคือผู้โจมตีไม่จำเป็นต้องเขียน SQL เอง เพียงพิมพ์ข้อความที่ชักนำให้ LLM เขียนคำสั่งอันตรายแทน และเนื่องจาก SQL ทั้งประโยคถูกสร้างขึ้นใหม่ทุกครั้ง เทคนิคป้องกัน SQL Injection แบบดั้งเดิมอย่างการใช้คิวรีแบบกำหนดพารามิเตอร์ (Parameterized Query) จึงไม่มีจุดให้ยึดเกาะ